

Phase,Component/Tool,Best Practice

Activity,Security Goal,Implementation Detail/  
Config,Priority

1. Static Code Analysis,Gitleaks,Scan full Git history for hardcoded secrets,Prevent credential leaks,Regex & Entropy scanning via GitHub Actions,Critical
2. Static Code Analysis,Kube-linter,Validate Kubernetes manifests against security rules,Enforce configuration standards,Ensure runAsNonRoot and resource limits,High
3. Static Code Analysis,Hadolint,Lint Dockerfiles for optimization and security,Minimize image vulnerabilities,Avoid using latest tags and root users,Medium
4. Secure Container Build,Docker Buildx,Compile multi-stage container images,Reduce attack surface,Separate build environment from final runtime,High

5. Secure Container Build,Base Images,Use Alpine or Distroless as base layers,Eliminate unnecessary OS utilities,Remove tools like curl apt and bash from prod,High
6. Image Vulnerability Scan,Trivy,Scan OS packages and application dependencies,Detect known CVEs before deployment,Fail pipeline if CRITICAL or HIGH CVEs found,Critical
7. Artifact Registry,GHCR / Docker Hub,Push verified container images to private registry,Ensure image provenance,Use Least Privilege permissions (packages:write),Medium
8. Cluster Admission Control,Kyverno / OPA,Enforce policies inside the cluster at runtime,Block manual unsecure deployments,Reject non-compliant YAMLS at API Server level,High
9. Runtime Application,Pod Lifecycle,Configure

Graceful Shutdown preStop hooks,Maintain  
zero-downtime rolling updates,Add sleep 15  
to allow network propagation,High